

Enterprise **Vulnerability** **Assessment** & Reconnaissance

A technical, non-intrusive perimeter security assessment performed against target `scanme.nmap.org` to analyze network footprints and service vulnerabilities.

Assessor:

Timnit Gebrelibanos

Program Host:

Future Interns

Organization:

Mekelle Institute of Technology

Target Domain:

`scanme.nmap.org` (45.33.32.156)



FUTURE
I N T E R N S



Executive Summary

An overarching perspective on our threat modeling, key target exposures, and core objectives of the perimeter audit.



01.1 SCOPE & MISSION OBJECTIVES

🎯 Audit Target & Scope

Passive and minimal active network scanning was structured against **scanme.nmap.org** (45.33.32.156) in strict compliance with ethical framework rules. Standard service versioning and application layer responses were parsed to construct an active vulnerability surface model.

🛡️ Mission Objective

To detect configuration anomalies, open port risks, and outdated software headers. The goal is to provide enterprise-grade remediation blueprints to successfully secure systems against opportunistic threat actors.

01.2

VULNERABILITY ASSESSMENT TOOLSET



Nmap Engine

Utilized for low-intensity TCP port mapping, transport layer state resolution, and service-level version fingerprinting.



OWASP ZAP

Leveraged for passive HTTP/HTTPS response header tracking to verify security configurations at the application level.



Terminal Audit

Used for raw TCP connections to analyze system banner leaks and server configuration declarations.



Technical Reconnaissance

Detailed evidence gathered from open ports, service responses, and system configurations.



02.1 PORT SCAN & SERVICE MAPPING LOG

Port	Protocol	State	Service Identifier	Fingerprinted Version
22	TCP	OPEN	SSH	OpenSSH 6.6.1p1 (Ubuntu Linux)
80	TCP	OPEN	HTTP	Apache httpd 2.4.7
9929	TCP	OPEN	Nping-echo	Nmap Nping echo service
31337	TCP	OPEN	Elite	tcpwrapped (Service firewall protected)



Vulnerability Risk Matrix

Standardized severity analysis of identified exposures based on CVSS v3 framework scoring.



03.1 CVSS SEVERITY SCORING BREAKDOWN

$$\text{BaseScore} = \text{roundUp} (\text{Minimum} (\text{Impact} + \text{Exploitability} , 10))$$

SEC-01-001 (SSH Exposure)

5.3 Medium

SEC-01-002 (Banner Leak)

5.3 Medium

SEC-01-003 (CSP Missing)

6.1 Medium

A severity cap of "Medium" is established across all three distinct CVE classes. No immediate critical hazards were located on the target environment.

**SEC-01-001: SSH Protocol Exposure (CVSS 5.3)**

Standard Linux SSH management interfaces are routed directly to the public web on Port 22. This invites constant brute-force dictionary attempts and password-guessing threat cycles.

**SEC-01-002: Outdated Server Software & Banners (CVSS 5.3)**

The host exposes precise application layer details (Apache/2.4.7, OpenSSH/6.6.1). Attackers easily scrape version signatures to align exact, pre-compiled public exploit scripts.

**SEC-01-003: Missing Content Security Policy Header (CVSS 6.1)**

Zero Content Security Policy rules are served inside server HTTP payloads. This creates XSS bypass options, opening pathways for script injection and UI redirection.

SSH Infrastructure Hardening

1. Restrict Port 22 connections with local firewalls (`UFW` or `iptables`) to known, trusted bastion IPs.
2. Edit `/etc/ssh/sshd\_config` to explicitly enforce `PubkeyAuthentication yes` and disable default password logins entirely.

Web Application Defense

1. Configure web server environments to minimize information disclosure. Inject server environment variables:

```
ServerTokens Prod
ServerSignature Off
```

2. Implement modern security headers (CSP, X-Frame-Options) directly within routing configurations.



Phase 1: Firewalls

Configure and isolate open network management ports via local firewalls and access lists.



Phase 2: Banners

Edit Apache configs to strip signatures and disable public version disclosures.



Phase 3: CSP

Inject Content Security Policies and HTTP headers into the system routing engine.



Phase 4: Audit

Run a second, follow-up scan to verify that all assets are secured and closed.

Questions & Answers

Thank you for your attention. This concludes the vulnerability assessment.



FUTURE
I N T E R N S

Presenter: Timnit Gebrelibanos

Email: ttimnit84@gmail.com

Affiliation: Mekelle Institute of Technology

Host Company: Future Interns